

Sind Sie CRA-ready?

Eine 30-Punkte-Checkliste entlang der sechs CRA-Säulen — für Produktverantwortliche, CTOs und Compliance-Teams. Nutzen Sie sie, um Lücken zu erkennen, bevor die Verpflichtungen ab 11.12.2027 vollständig greifen.

Version 1.0 · 2026	Herausgeber SantosLab GmbH	Kontakt hello@santoslab.de
------------------------------	--------------------------------------	--------------------------------------

1 · Secure by Design & by Default

	Bedrohungsmodellierung (STRIDE o.ä.) ist für jedes Produkt dokumentiert und wird pro Release aktualisiert.
	Sichere Default-Konfiguration: kein Auslieferungszustand mit offenen Ports, Standardpasswörtern oder deaktiviertem TLS.
	Least-Privilege-Prinzip für alle Runtime-Komponenten und Service-Accounts.
	Kryptografische Verfahren entsprechen aktuellen BSI-/ENISA-Empfehlungen (kein SHA-1, kein RSA<2048).
	Security-Anforderungen sind Teil der Definition of Done, nicht nachgelagert.

2 · SBOM & Lieferkette

	Vollständige, maschinenlesbare SBOM (CycloneDX oder SPDX) pro Release, inkl. transitiver Abhängigkeiten.
	SBOM wird automatisiert in der CI/CD erzeugt und versioniert archiviert.
	Third-Party- und Open-Source-Komponenten werden mit Lizenz- und Herkunftsnachweis geführt.
	Prozess für Reaktion auf kompromittierte Upstream-Pakete ist dokumentiert (Beispiel: xz-utils-Backdoor).
	Container-Images werden signiert (Cosign/Sigstore) und in einer privaten Registry gescannt.

3 · Vulnerability Management

	Coordinated Vulnerability Disclosure (CVD) mit security.txt und dediziertem Meldekanal.
	SLA für Bewertung, Fix und Rollout je CVSS-Klasse ist definiert und wird gemessen.
	SCA-, SAST- und DAST-Scans laufen mindestens täglich in der Pipeline.
	CVE-Monitoring für alle in der SBOM geführten Komponenten inkl. automatischer Ticket-Erstellung.
	Patch-Delivery-Prozess für Bestandskund:innen inkl. Deprecation-Policy ist geregelt.

4 · Meldepflichten (24h / 72h)

	Playbook für aktiv ausgenutzte Schwachstellen erfüllt die 24-Stunden-Frühwarnung an ENISA/CSIRT.
	Nachmeldung mit technischen Details innerhalb 72 Stunden ist prozessual abgebildet.
	Kundenkommunikation (Advisory, betroffene Versionen, Mitigation) ist als Template vorhanden.
	Interne Rollen (Incident Lead, Legal, Communications, Engineering) sind namentlich zugewiesen.
	Übungen (Tabletop, Red-Team) finden mindestens jährlich statt und werden protokolliert.

5 · Dokumentation & Konformität

	Technische Dokumentation nach Anhang V CRA ist gepflegt und versioniert.
	Konformitätsbewertung (Modul A / B+C / H) je Produkt ist festgelegt und begründet.
	EU-Konformitätserklärung und CE-Kennzeichnung sind vorbereitet bzw. vorhanden.
	Benutzerinformationen (Sicherheitsupdate-Zeitraum, sichere Nutzung) sind für Endkund:innen zugänglich.
	Risikoanalyse ist als lebendes Dokument geführt und mit Releases verknüpft.

6 · Support & Updates

	Sicherheitsupdate-Zeitraum ist definiert (mindestens erwartete Produktlebensdauer, i.d.R. 5 Jahre).
	Automatische oder klar kommunizierte Update-Mechanismen sind produktseitig implementiert.
	End-of-Life-Prozess mit Vorlaufzeit, Migrationspfad und finaler Security-Patch-Phase existiert.
	Monitoring erkennt veraltete Installationen im Feld und triggert Update-Empfehlungen.
	Vertragliche Regelungen mit Kund:innen decken die CRA-Pflichten und Haftungsverteilung ab.

Timeline · Wichtige CRA-Fristen

10.12.2024	CRA im EU-Amtsblatt · Inkrafttreten
11.09.2026	Meldepflichten für aktiv ausgenutzte Schwachstellen (24h/72h)
11.12.2027	Volle Anwendung · CE-Kennzeichnung Pflicht

Nächster Schritt

Sie haben mehr als fünf offene Punkte? Dann lohnt sich eine strukturierte Gap-Analyse. SantosLab liefert innerhalb von 48 Stunden einen priorisierten Report inkl. konkreter Maßnahmenliste und Aufwandsschätzung.

hello@santoslab.de · santoslab.de/cra

© SantosLab GmbH · Diese Checkliste ist eine praxisorientierte Orientierungshilfe und ersetzt keine juristische Beratung.